



Corporación Unificada Nacional
de Educación Superior

Corporación Unificada Nacional de Educación Superior — CUN

Programa de Ingeniería de Sistemas

**RASTRO: SISTEMA DE TRAZABILIDAD VERIFICABLE DE ENVÍOS PARA
EMPRESAS DE MENSAJERÍA URBANA SOBRE SERVICIOS GESTIONADOS EN LA
NUBE**

ENTREGA 2 · AJUSTE AVANZADO DE PROYECTO

Presentado por:

Sergio Alejandro Montoya Granados

sergio.montoya@cun.edu.co

Nicolás Torres Perdomo

nicolas.perdomot@cun.edu.co

Oscar Julián Rincón Bejarano

oscar.rinconbbe@cun.edu.co

Cloud Computing (ISD38) · Grupo 30112 · Periodo 2026B

Bogotá, D. C., Colombia · Septiembre de 2026



Programa de Ingeniería de Sistemas

**RASTRO: SISTEMA DE TRAZABILIDAD VERIFICABLE DE ENVÍOS PARA
EMPRESAS DE MENSAJERÍA URBANA SOBRE SERVICIOS GESTIONADOS EN LA
NUBE**

Documento académico de proyecto

Presentado a:

Daniel Alejandro García Rodríguez

Asignatura: Cloud Computing (ISD38)

Versión: 1.0

Fecha de entrega: 3 de octubre de 2026

Corporación Unificada Nacional de Educación Superior — CUN

Bogotá, D. C., Colombia

Control del documento

La Tabla 1 identifica el proyecto, el equipo y la versión de este documento.

Tabla 1

Identificación del proyecto y del equipo de trabajo

Campo	Información
Título del proyecto	Rastro: sistema de trazabilidad verificable de envíos para empresas de mensajería urbana sobre servicios gestionados en la nube
Asignatura y grupo	Cloud Computing (ISD38) · Grupo 30112 · Periodo 2026B
Integrantes	Sergio Alejandro Montoya Granados — sergio.montoya@cun.edu.co Nicolás Torres Perdomo — nicolas.perdomot@cun.edu.co Oscar Julián Rincón Bejarano — oscar.rinconbbe@cun.edu.co
Docente	Daniel Alejandro García Rodríguez
Versión	1.0 — sustituye la versión 0.1 presentada en la Entrega 1
Repositorio de evidencias	https://github.com/Serann10255/Rastro Repositorio público. Contiene el código, la secuencia de despliegue, las decisiones de arquitectura, la documentación técnica y las evidencias de despliegue.
Entorno desplegado	Cuenta AWS 484948252891 · región us-east-1 · verificado el 26 de septiembre de 2026
Fecha de corte	3 de octubre de 2026

Tabla de contenido

Control del documento.....	3
Tabla de contenido.....	4
Matriz obligatoria de atención a la retroalimentación	7
1. Resumen ejecutivo, abstract y palabras clave.....	8
1.1 Resumen.....	8
1.2 Abstract and keywords.....	9
2. Introducción y evolución del proyecto	10
3. Problema, pregunta, objetivos y alcance ajustados.....	11
3.1 Problema y pregunta validados	11
3.2 Objetivos y trazabilidad	12
3.3 Alcance, exclusiones y restricciones.....	13
4. Marco referencial actualizado.....	14
4.1 Estado del arte y antecedentes	15
4.2 Marco teórico y conceptual.....	15
4.3 Marco contextual	16
4.4 Marco normativo, ético y de estándares	17
5. Partes interesadas, necesidades y requisitos consolidados	18
5.1 Actores y partes interesadas.....	18
5.2 Requisitos funcionales, no funcionales y criterios de aceptación.....	19

5.3 Historias de usuario, casos de uso o procesos.....	21
6. Arquitectura de la solución	21
6.1 Diagrama de contexto y límites	21
6.2 Componentes, contenedores y topología	22
6.3 Decisiones de arquitectura	24
7. Diseño detallado.....	26
7.1 Modelo de datos e información.....	26
7.2 Diseño de interfaces e interacción	27
7.3 Integraciones, API, protocolos y configuración	28
8. Implementación, configuración y prototipo.....	30
8.1 Evidencia de la implementación desplegada	30
9. Verificación, validación y pruebas	31
9.1 Estrategia de pruebas	31
9.2 Casos, resultados y defectos	32
9.3 Validación con usuarios o expertos	33
10. Seguridad, privacidad, ética y cumplimiento.....	35
11. Calidad, mantenibilidad y operación	37
12. Gestión del proyecto	38
12.1 Metodología, fases y roles	38
12.2 Cronograma e hitos	39

12.3 Repositorio, versiones y gestión de cambios	40
12.4 Presupuesto y recursos	41
13. Viabilidad y gestión de riesgos actualizadas	41
14. Resultados y discusión	43
15. Conclusiones, recomendaciones y trabajo futuro	44
15.1 Conclusiones	44
15.2 Recomendaciones y trabajo futuro	45
Referencias	47
Anexos técnicos	49

Matriz obligatoria de atención a la retroalimentación

La evaluación de la Entrega 1 registró una única observación, de prioridad baja. Se transcribe de forma literal, con la acción aplicada, su ubicación y la evidencia que permite comprobarla. El equipo añade además dos hallazgos de gestión detectados por iniciativa propia durante la construcción, identificados con el prefijo HD para distinguirlos de los hallazgos que emite el programa de auditoría.

La Tabla 2 recoge la observación recibida y los hallazgos propios, con su estado y su evidencia.

Tabla 2

Atención a la retroalimentación de la Entrega 1

ID	Retroalimentación literal	Respuesta del equipo	Ubicación del cambio	Evidencia	Estado
OBS-01	«El repositorio de evidencias indica que se habilitará al inicio de la fase 3. Acción requerida: registrar la URL del repositorio público en GitHub al iniciar la codificación.»	Se habilitó el repositorio público y se registró su dirección en el control del documento. Contiene además la documentación técnica, las once decisiones de arquitectura y las evidencias de despliegue.	Control del documento, celda Repositorio; apartados 8 y 12.3	https://github.com/Serann10255/Rastro	Resuelta
HD-01	Hallazgo propio: el archivo de configuración con el secreto de firma de sesiones quedó versionado en el repositorio público durante 27 minutos.	Rotación del secreto y redespliegue de las ocho funciones; exclusión del archivo del control de versiones; verificación de que ningún secreto	Apartado 10; documentacion/cambios/2026-09-26-h01-secreto-expuesto.md	evidencias-despliegue/20260926T232257Z-rotacion-secreto.txt	Resuelta

ID	Retroalimentación literal	Respuesta del equipo	Ubicación del cambio	Evidencia	Estado
		anterior es aceptado. Sin indicios de explotación en la ventana de exposición.			
HD-02	Hallazgo propio derivado del anterior: el secreto permanece en el historial de commits aunque ya no figure en la rama.	Se acepta el riesgo residual de forma temporal. El secreto fue invalidado, de modo que su presencia en el historial es una limpieza pendiente y no una puerta abierta. La reescritura del historial queda como acción programada.	Apartados 10 y 15.2	Control C-09b del informe de auditoría, ejecución 20260926T235724886Z-4f87a8	Aceptada con plan

Nota. La observación OBS-01 se transcribe con la redacción de la matriz de retroalimentación docente. Los hallazgos HD se numeran con prefijo propio para no colisionar con los hallazgos que emite el programa de auditoría, que llevan su propia secuencia.

1. Resumen ejecutivo, abstract y palabras clave

1.1 Resumen

Las empresas de mensajería de pequeño tamaño registran el avance de sus envíos por teléfono, chat y hojas de cálculo, de modo que no conservan quién cambió el estado de un envío, cuándo lo hizo ni con qué evidencia. El objetivo fue desarrollar un sistema que obligue a que cada cambio quede atribuido, fechado y validado contra un conjunto de transiciones permitidas, y cuyo registro pueda comprobarse después. El método combinó un enfoque iterativo con verificación continua: cada requisito se tradujo a pruebas automatizadas antes de darse por cumplido. El resultado es Rastro, un sistema desplegado en Amazon Web Services sobre ocho funciones sin servidor, tres tablas de datos, almacenamiento cifrado con llave administrada y registro de actividad con

validación de integridad, todo ello en infraestructura compartida por varias empresas con aislamiento estricto de sus datos. La validación se realizó en tres planos: 238 pruebas automatizadas, de las cuales 234 pasan y 4 quedan omitidas; la verificación posterior al despliegue, que confirma la existencia y respuesta de cada componente; y una auditoría independiente ejecutada por un programa construido para ese fin, que evaluó once controles trazados a marcos de referencia y obtuvo diez conformes y uno desviado. El control desviado corresponde a un secreto que permanece en el historial del repositorio, ya invalidado. Se concluye que el sistema cumple los nueve requisitos comprometidos y que sus dos limitaciones estructurales, derivadas del entorno educativo, quedan declaradas en lugar de omitidas.

Palabras clave: trazabilidad verificable, computación en la nube, arquitectura sin servidor, aislamiento multiempresa, auditoría automatizada de controles.

1.2 Abstract and keywords

Small urban courier companies record shipment progress through phone calls, chat messages and shared spreadsheets, which means they do not retain who changed a shipment's status, when, or with what supporting evidence. The objective was to develop a system that forces every change to be attributed, timestamped and validated against a set of permitted transitions, and whose record can be verified afterwards. The method combined an iterative approach with continuous verification: each requirement was translated into automated tests before being considered fulfilled. The result is Rastro, a system deployed on Amazon Web Services over eight serverless functions, three data tables, storage encrypted with a customer-managed key, and activity logging with file integrity validation, all running on infrastructure shared by several companies with strict isolation of their data. Validation was carried out on three levels: 238 automated tests, of which

234 pass and 4 are skipped; post-deployment verification confirming the existence and response of every component; and an independent audit performed by a program built for that purpose, which evaluated eleven controls traced to reference frameworks and returned ten compliant and one deviated. The deviated control corresponds to a secret that remains in the repository history and has already been invalidated. The system meets the nine committed requirements, and its two structural limitations, arising from the educational environment, are declared rather than omitted.

Keywords: verifiable traceability, cloud computing, serverless architecture, multi-tenant isolation, automated control auditing.

2. Introducción y evolución del proyecto

La Entrega 1 presentó Rastro como una idea delimitada: cinco operaciones sobre el ciclo de vida del envío, identidad delegada en un servicio gestionado del proveedor y un conjunto de supuestos técnicos pendientes de validar. Este documento presenta el mismo proyecto después de construirlo, desplegarlo y someterlo a verificación. Tres cosas cambiaron durante ese recorrido, y las tres están registradas como decisiones de arquitectura en el repositorio para que el código y el documento no se contradigan.

La primera es la ampliación del alcance. El equipo decidió construir un sistema de gestión de transporte utilizable en operación real y no una demostración de cinco operaciones, lo que exigió cuentas administrables, catálogos de clientes, tiendas y transportistas, registro masivo, generación de guías y un tablero de operación. La decisión, con lo que entra y lo que sigue excluido, está documentada; los nueve requisitos comprometidos en la Entrega 1 se mantienen íntegros y se verifican uno a uno en el apartado 9.

La segunda es la sustitución del proveedor de identidad. El diseño original delegaba la autenticación en un grupo de usuarios gestionado por el proveedor de nube. Al necesitar administrar cuentas desde la propia aplicación, esa opción dejó de servir: el laboratorio no concede los permisos de administración necesarios y depender de la consola del proveedor para dar de alta a un mensajero no es una operación que una microempresa vaya a realizar. El sistema tiene ahora su propio servicio de identidad, con contraseñas derivadas mediante PBKDF2-HMAC-SHA256 con sal por contraseña y el número de iteraciones que recomienda la guía de almacenamiento de contraseñas de la OWASP Foundation (s. f.), y con sesiones revocables.

La tercera es el paso de cinco funciones previstas a ocho servicios desplegados, consecuencia directa de la ampliación anterior. El límite entre servicios sigue el mismo criterio que la Entrega 1 fijó para las operaciones: cada uno atiende una responsabilidad del proceso y comparte una única capa de acceso a datos que aplica el control de autorización sin excepción.

Lo que no cambió es el núcleo del problema ni los dos controles que diferencian la propuesta: la máquina de estados que rechaza transiciones inválidas y la bitácora encadenada por funciones hash que permite detectar alteraciones posteriores. Ambos están contruidos, probados y auditados. Los apartados 3 a 5 presentan el problema y los requisitos ya validados, del 6 al 8 la arquitectura y la implementación desplegada, el 9 la verificación, del 10 al 13 la seguridad, la calidad, la gestión y los riesgos, y los apartados 14 y 15 los resultados y las conclusiones.

3. Problema, pregunta, objetivos y alcance ajustados

3.1 Problema y pregunta validados

En una empresa de mensajería de pequeño tamaño el estado de un envío existe de forma dispersa: en la memoria del mensajero, en un mensaje de chat, en una anotación de una hoja de cálculo y en

la llamada que el despachador hace para confirmar. No existe un registro único que indique quién cambió el estado, cuándo lo hizo y con qué respaldo. La situación deseada es la contraria: cada cambio de estado asociado a un responsable identificado, a una marca de tiempo y, cuando corresponde, a una evidencia almacenada.

Origen y limitaciones de la evidencia. El proyecto no surgió de un estudio de campo sino de la experiencia laboral de los integrantes en organizaciones que operan procesos de despacho y entrega, donde convivieron con sistemas de seguimiento que no conservaban el autor de cada cambio ni la evidencia de la entrega. Por compromisos de confidencialidad no se identifican esas organizaciones. Esa base tiene tres limitaciones que se enuncian en lugar de disimular: es observación no sistemática, no dispone de mediciones de frecuencia ni de magnitud, y no es generalizable al sector. Por eso las afirmaciones se apoyan además en dos elementos verificables: las propiedades conocidas de las herramientas empleadas, pues una hoja de cálculo compartida admite editar el histórico sin dejar rastro del cambio ni de su autor, y la literatura citada en el apartado 4.

La pregunta de proyecto se mantiene y, a diferencia de la Entrega 1, ahora puede responderse con evidencia: ¿cómo diseñar e implementar un sistema de rastreo de envíos, desplegado sobre servicios gestionados en la nube, que registre de forma verificable cada cambio de estado con su responsable y su evidencia, y que restrinja las operaciones según el rol del usuario, en las condiciones de permisos y presupuesto de un entorno educativo restringido? El apartado 14 discute la respuesta obtenida.

3.2 Objetivos y trazabilidad

Objetivo general. Desarrollar un sistema de rastreo de envíos sobre servicios gestionados de Amazon Web Services que registre de forma verificable el ciclo de vida de cada envío, con control

de acceso basado en roles, aislamiento de datos entre organizaciones y evidencia de entrega cifrada, para empresas de mensajería de pequeño tamaño que comparten una misma infraestructura.

La Tabla 3 traza cada objetivo específico hasta su evidencia y su estado de cumplimiento.

Tabla 3

Objetivos específicos, evidencia y estado de cumplimiento

ID	Objetivo específico	Entregable	Evidencia verificable	Estado
OE-1	Caracterizar el proceso actual de registro y seguimiento de envíos, identificando los puntos en que se pierde la información.	Diagnóstico del proceso y mapa de actores.	Apartados 3.1 y 5.1; visión general de arquitectura en el repositorio.	Cumplido con la limitación declarada en 3.1
OE-2	Diseñar la arquitectura y el modelo de datos conforme a las restricciones verificadas del entorno.	Arquitectura, modelo de datos, matriz de autorización y once decisiones registradas.	Apartados 6 y 7; carpeta de decisiones de arquitectura del repositorio.	Cumplido
OE-3	Construir y desplegar los componentes del sistema sobre los servicios gestionados disponibles.	Sistema desplegado y secuencia de despliegue reproducible.	Apartado 8; salida de la verificación posterior al despliegue del 26 de septiembre de 2026.	Cumplido
OE-4	Verificar mediante pruebas que los controles de acceso, de integridad de estados y de trazabilidad funcionan según lo diseñado.	Informe de pruebas y auditoría independiente de controles.	Apartado 9; 234 pruebas automatizadas en verde e informe de auditoría con once controles evaluados.	Cumplido

3.3 Alcance, exclusiones y restricciones

El alcance se amplió respecto de la Entrega 1 por la decisión descrita en el apartado 2. La tabla siguiente refleja el estado actual y no el previsto.

La Tabla 4 delimita el alcance vigente del sistema.

Tabla 4

Alcance vigente: elementos construidos, excluidos y condicionados

Condición	Elemento	Estado y justificación
Construido	Ciclo de vida del envío: registro con identificador no predecible, asignación, puntos de control y entrega.	Operativo. Verificado por REQ-01 a REQ-03.
Construido	Consulta pública del histórico por identificador, sin autenticación.	Operativo. Verificado por REQ-04.
Construido	Evidencia de entrega cifrada con llave administrada por el proyecto.	Operativo. Verificado por REQ-05 y por el control C-02 de la auditoría.
Construido	Aislamiento de datos entre organizaciones en clave de partición, token y ruta de almacenamiento.	Operativo. Verificado por REQ-06 y por el control C-06.
Construido	Autorización por rol con registro de las operaciones permitidas y rechazadas.	Operativo. Cinco roles configurables. Verificado por REQ-07 y por el control C-05.
Construido	Bitácora de auditoría encadenada por funciones hash, con verificador.	Operativo. Verificado por REQ-08 y por el control C-08.
Construido	Despliegue reproducible y procedimiento de migración a otra cuenta.	Operativo e idempotente. Verificado por REQ-09.
Ampliación	Directorio de usuarios propio, catálogos de clientes, tiendas y transportistas, registro masivo, guías y tablero de operación.	Construido. Amplía el alcance de la Entrega 1 por decisión registrada.
Excluido	Registro autónomo de nuevas organizaciones y su interfaz comercial.	Las organizaciones se aprovisionan mediante la secuencia de despliegue. Pertenecen a un modelo de negocio ajeno al problema.
Excluido	Rastreo por posición continua del vehículo.	Exige dispositivos y un volumen de datos fuera del presupuesto. Además implicaría vigilancia del trabajador, excluida por la decisión ética del apartado 10.
Excluido	Optimización de rutas, aplicación móvil nativa y notificaciones automáticas.	Requieren datos, dispositivos o servicios no disponibles. La interfaz web adaptable cubre el caso de uso móvil.
Condicionado	Retención inmutable del almacenamiento de evidencias.	No habilitada. El entorno no confirmó su disponibilidad. Se sustituye por versionado más verificación de integridad y se declara como limitación.

Las restricciones del entorno se mantienen: imposibilidad de crear roles de identidad y acceso, bloqueo de la invocación anónima de funciones, región única, presupuesto de 50 dólares por cuenta y detención de las instancias de cómputo al cerrar cada sesión. El supuesto SU-01 de la Entrega 1, relativo al validador de tokens de la puerta de enlace, quedó resuelto por una decisión de diseño que lo vuelve indiferente y se explica en el apartado 6.3.

4. Marco referencial actualizado

4.1 Estado del arte y antecedentes

El rastreo de envíos está resuelto en el segmento de los grandes operadores logísticos y desatendido en el de las microempresas. Las soluciones disponibles se agrupan en cuatro categorías: hojas de cálculo compartidas con mensajería instantánea, plataformas comerciales de última milla por suscripción, servicios de rastreo de operadores postales y desarrollos propios sobre infraestructura administrada. Ninguna ofrece a un operador pequeño un registro cuya integridad pueda verificar él mismo, con un procedimiento definido y sin depender de la palabra del proveedor.

El problema de conservar un registro cuya integridad pueda comprobarse después no es propio de la logística ni es reciente. Haber y Stornetta (1991) propusieron encadenar documentos mediante funciones hash, de modo que cada registro incorpore el resultado de aplicar la función al anterior; alterar un documento intermedio obliga a recalcular toda la cadena posterior y la manipulación se vuelve detectable. Schneier y Kelsey (1999) trasladaron esa idea a los registros de sistemas y demostraron que una bitácora puede diseñarse para que la modificación de cualquier entrada previa sea evidenciable incluso si el atacante controla la máquina. Ambos trabajos son el antecedente directo de la bitácora construida, cuya implementación se describe en el apartado 7.1.

Kent y Souppaya (2006) establecieron que un registro de auditoría útil debe conservar como mínimo quién ejecutó la acción, qué acción fue, sobre qué recurso y en qué momento; esa cuádrupla es la estructura que adopta la bitácora. La OWASP Foundation (2021) sitúa el control de acceso deficiente en el primer lugar de su listado de riesgos e incluye allí la referencia directa insegura a objetos, que es el riesgo evitado al emplear identificadores aleatorios en el punto de consulta pública.

4.2 Marco teórico y conceptual

Cuatro conceptos sostienen el diseño. El primero es la **cadena de custodia**, entendida como la secuencia documentada de responsables por los que pasa un bien, cada uno identificado y con el momento de la transferencia registrado; es el concepto que el sistema traslada del ámbito forense al del transporte urbano.

El segundo es el **registro a prueba de manipulación**, que no impide la alteración sino que la hace detectable. La distinción importa: un control de integridad no promete que la evidencia sobreviva, promete que si cambió se sabe. El apartado 10 delimita hasta dónde llega esa promesa en el entorno disponible.

El tercero es el **control de acceso basado en roles**, en el que los permisos se asocian a funciones organizativas y no a personas. El sistema lo implementa con cinco roles y permite definir roles nuevos sin modificar el código, porque el reparto de permisos vive en los datos y no en el programa.

El cuarto es el **aislamiento multiempresa**, es decir, la garantía de que varias organizaciones puedan compartir una misma infraestructura sin que ninguna alcance los datos de otra. La decisión de incorporarlo desde el modelo de datos y no como una capa posterior es la que hace que el aislamiento sea una propiedad estructural: sin el identificador de organización, que forma parte de la clave de partición, la consulta no puede construirse.

4.3 Marco contextual

El sistema se dirige a empresas de mensajería urbana de pequeño tamaño que operan en Bogotá con flotas reducidas y atienden a clientes corporativos. El modelo de entrega es de infraestructura compartida, porque una microempresa no puede costear un despliegue propio; esa condición del contexto es la que convierte el aislamiento de datos en un requisito y no en una funcionalidad opcional.

El desarrollo se realizó en AWS Academy Learner Lab, un entorno educativo con un subconjunto restringido de servicios, presupuesto acotado y sesiones de trabajo de cuatro horas. Las condiciones del entorno no fueron un obstáculo administrativo sino un insumo de diseño: determinaron la elección de cómputo bajo demanda, la exclusión de los recursos que facturan de forma continua y la exigencia de que todo el despliegue fuera reproducible.

4.4 Marco normativo, ético y de estándares

El sistema trata datos personales: nombre del destinatario, dirección de entrega, geolocalización de los puntos de control y fotografías de la entrega. En Colombia ese tratamiento está regulado por la Ley 1581 de 2012 y el Decreto 1377 de 2013, que exigen autorización previa del titular, finalidad determinada, minimización y medidas de seguridad proporcionales al riesgo, bajo vigilancia de la Superintendencia de Industria y Comercio. El sistema se pobló exclusivamente con datos sintéticos, de modo que el proyecto no genera obligaciones de tratamiento sobre titulares reales; las medidas que exigiría un tratamiento real están no obstante implementadas y verificadas.

La Tabla 5 relaciona cada estándar aplicado con su efecto verificable en el sistema.

Tabla 5

Estándares y marcos aplicados, con su efecto verificable

Marco o norma	Aspecto que regula	Efecto verificable en el sistema
Ley 1581 de 2012 y Decreto 1377 de 2013	Tratamiento de datos personales.	Minimización de la captura, cifrado en reposo y restricción de consulta por rol. Operación con datos sintéticos.
ISO/IEC 27001:2022, A.8.24 y A.8.13 (International Organization for Standardization, 2022)	Criptografía y copias de seguridad.	Cifrado con llave administrada por el proyecto y versionado del almacenamiento. Controles C-02 y C-04 conformes.
ISO/IEC 27001:2022, A.5.17 y A.8.4	Información de autenticación y acceso al código fuente.	Exclusión de secretos del control de versiones. Controles C-09a y C-09c conformes; C-09b desviado, con plan.

Marco o norma	Aspecto que regula	Efecto verificable en el sistema
CIS AWS Foundations Benchmark (Center for Internet Security, s. f.)	Configuración segura de una cuenta de nube.	Registro de actividad activo con validación de integridad y bloqueo de acceso público. Controles C-01 y C-03 conformes.
OWASP Top 10:2021, A01	Control de acceso deficiente.	Identificadores aleatorios, autorización por operación y respuesta 404 ante recursos de otra organización. Controles C-05 y C-06 conformes.
NIST SP 800-92 (Kent y Souppaya, 2006)	Gestión de registros de seguridad.	La bitácora conserva actor, acción, recurso, momento y resultado.
Marco de buenas prácticas del proveedor, pilar de seguridad (Amazon Web Services, 2024)	Principio de mínimo privilegio.	No se cumple. El entorno impide crear roles y la desviación se declara como hallazgo permanente.

5. Partes interesadas, necesidades y requisitos consolidados

5.1 Actores y partes interesadas

La Tabla 6 relaciona cada actor con su necesidad y su relación con el sistema construido.

Tabla 6

Actores del sistema y sus necesidades

Actor	Papel en el proceso	Necesidad observable	Relación con el sistema
Administrador	Configura el sistema, administra cuentas y define roles.	Controlar quién accede y con qué permisos, sin depender de la consola del proveedor.	Usuario con el mayor nivel de privilegio. Gestiona usuarios, roles y catálogos.
Despachador	Registra envíos, asigna mensajero y autoriza la reanudación tras una incidencia.	Conocer el estado de cada envío sin llamar al mensajero.	Origina la mayoría de las operaciones de escritura.
Coordinador	Supervisa la operación diaria y el tablero.	Ver la carga de trabajo y los envíos detenidos.	Acceso de lectura amplio y operaciones de asignación.
Conductor o mensajero	Ejecuta recolección, traslado y entrega; registra puntos de control y carga la evidencia.	Reportar avance desde el celular sin depender de una llamada.	Permisos restringidos a los envíos que tiene asignados.
Auditor interno	Revisa la actividad registrada para verificar el cumplimiento del procedimiento.	Consultar qué ocurrió sin poder modificarlo.	Acceso exclusivo de lectura a la bitácora y a su verificación.

Actor	Papel en el proceso	Necesidad observable	Relación con el sistema
Destinatario	Recibe el envío y acepta la entrega.	Consultar el avance del envío que espera.	Actor externo sin cuenta; consulta mediante el identificador del envío.

Nota. El cliente remitente, que contrata el servicio, no figura como actor del sistema: consulta a través del destinatario o del despachador. La distinción entre cliente y usuario importa porque los requisitos se derivan de las necesidades de quienes operan el sistema.

5.2 Requisitos funcionales, no funcionales y criterios de aceptación

Los nueve requisitos comprometidos en la Entrega 1 se mantienen sin cambios en su enunciado ni en su criterio de aceptación. Lo que se añade en esta entrega es la columna de verificación: el conjunto de pruebas automatizadas que lo comprueba y el control de auditoría independiente que lo evalúa, cuando existe.

La Tabla 7 relaciona cada requisito con su criterio de aceptación y la evidencia que lo verifica.

Tabla 7

Requisitos consolidados con su verificación

ID	Tipo	Requisito	Criterio de aceptación	Verificación
REQ-01	F	Registrar un envío y asignarle un identificador único no predecible.	Dado un despachador autenticado, cuando registra un envío, entonces el sistema devuelve un identificador único universal y crea el registro maestro en estado CREADO.	tests/e2e/test_ciclo_de_vida.py
REQ-02	F	Registrar cada punto de control con estado, ubicación, autor y marca de tiempo.	Dado un conductor autenticado, cuando registra un punto de control, entonces el evento queda almacenado con el identificador del usuario y la marca de tiempo del servidor.	tests/e2e/test_ciclo_de_vida.py
REQ-03	F	Rechazar toda transición de estado no contemplada en la	Dado un envío en estado CREADO, cuando se solicita la transición a	tests/unit/test_maquina_estados.py y control C-07

ID	Tipo	Requisito	Criterio de aceptación	Verificación
		máquina de estados.	ENTREGADO, entonces el sistema responde 400 y registra el intento con resultado DENY.	
REQ-04	F	Consultar el histórico completo de un envío por su identificador, sin autenticación.	Dado un identificador válido, cuando se consulta el envío, entonces se devuelven el registro maestro y sus eventos en orden cronológico.	tests/e2e/test_consulta_publica_y_bitacora.py
REQ-05	F	Cargar evidencia de entrega mediante enlace prefirado de vigencia limitada, almacenada cifrada.	Dado un conductor autenticado, cuando solicita cargar evidencia, entonces recibe un enlace válido por un tiempo definido y el archivo queda cifrado con la llave del proyecto.	tests/e2e/test_ciclo_de_vida.py y control C-02
REQ-06	NF	Impedir que un usuario acceda a envíos, eventos o evidencias de otra organización.	Dado un usuario de la organización A, cuando solicita un envío de la organización B, entonces el sistema responde como si el recurso no existiera y registra el intento con resultado DENY.	tests/e2e/test_control_de_acceso_y_aislamiento.py y control C-06
REQ-07	NF	Restringir cada operación a los grupos autorizados y dejar constancia de permitidas y rechazadas.	Dado un usuario del grupo conductor, cuando invoca la creación de envíos, entonces el sistema responde 403 y existe un registro con actor, grupo, acción, recurso y resultado DENY.	tests/unit/test_autorizacion_y_claves.py, tests/e2e/test_roles.py y control C-05
REQ-08	NF	Permitir detectar la alteración o eliminación de cualquier registro de la bitácora.	Dada una bitácora con registros, cuando se modifica uno directamente en el almacén y se ejecuta el verificador, entonces este señala el punto en que la cadena se rompe.	tests/unit/test_bitacora_encadenada.py y control C-08
REQ-09	NF	Trasladar despliegue y datos	Dada una cuenta vacía, cuando se ejecuta la	deploy/aws/desplegar.sh, migrar.sh y 95-verificar.sh

ID	Tipo	Requisito	Criterio de aceptación	Verificación
		a otra cuenta mediante comandos versionados, sin identificadores escritos a mano.	secuencia de despliegue y la carga de datos, entonces el sistema queda operativo sin editar código ni intervenir en la consola.	

Nota. F corresponde a requisito funcional y NF a no funcional. La columna de verificación indica el artefacto que comprueba el requisito; los resultados obtenidos se presentan en el apartado 9.2.

5.3 Historias de usuario, casos de uso o procesos

El proceso cubierto va desde la recepción de la solicitud hasta el cierre del envío con evidencia, y comprende siete pasos: recepción, registro, asignación de mensajero, recolección, tránsito, reparto y entrega con captura de evidencia. Los dos puntos críticos, que son donde hoy se pierde la información, son el registro de cada cambio de estado y la captura de la evidencia final.

El caso de uso principal se ejecuta así. El despachador registra el envío y el sistema genera un identificador aleatorio; asigna un mensajero, lo que constituye la primera transferencia de custodia; el mensajero registra cada punto de control desde su dispositivo y, al entregar, carga la evidencia, que se almacena cifrada; el destinatario consulta el avance con el identificador, sin necesitar cuenta; y el auditor revisa la bitácora sin poder modificarla. Cada uno de esos pasos escribe un registro atribuido en la bitácora, tanto si la operación se autoriza como si se rechaza.

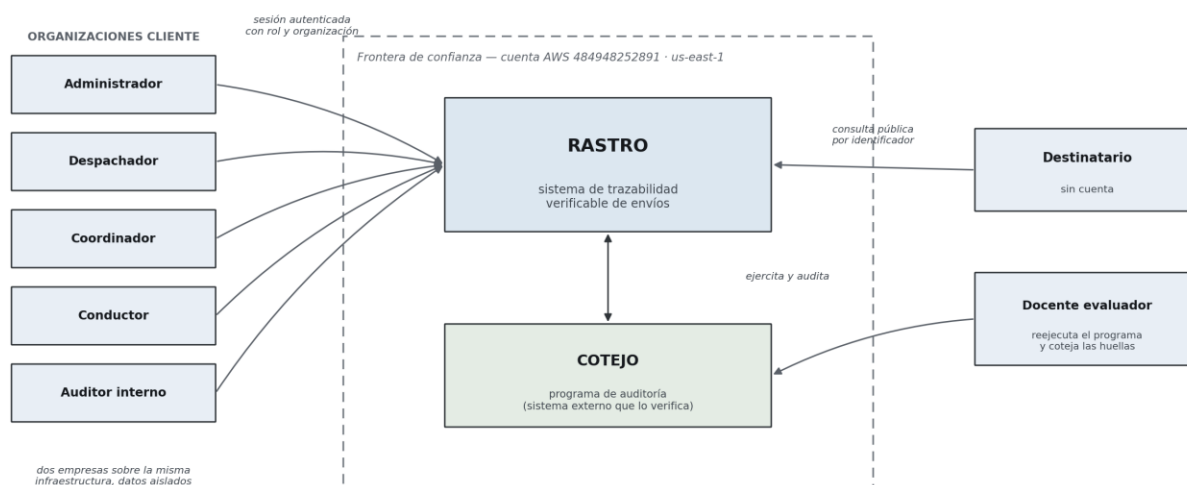
6. Arquitectura de la solución

6.1 Diagrama de contexto y límites

La Figura 1 sitúa el sistema frente a sus actores, sus sistemas externos y la frontera de confianza.

Figura 1

Diagrama de contexto y límites del sistema



Nota. La frontera de confianza coincide con la cuenta del proveedor. Los cinco roles operativos acceden con sesión autenticada que transporta rol y organización; el destinatario consulta sin cuenta mediante el identificador del envío. Cotejo, el programa de auditoría, se representa como sistema externo que ejerce a Rastro por sus mismas interfaces.

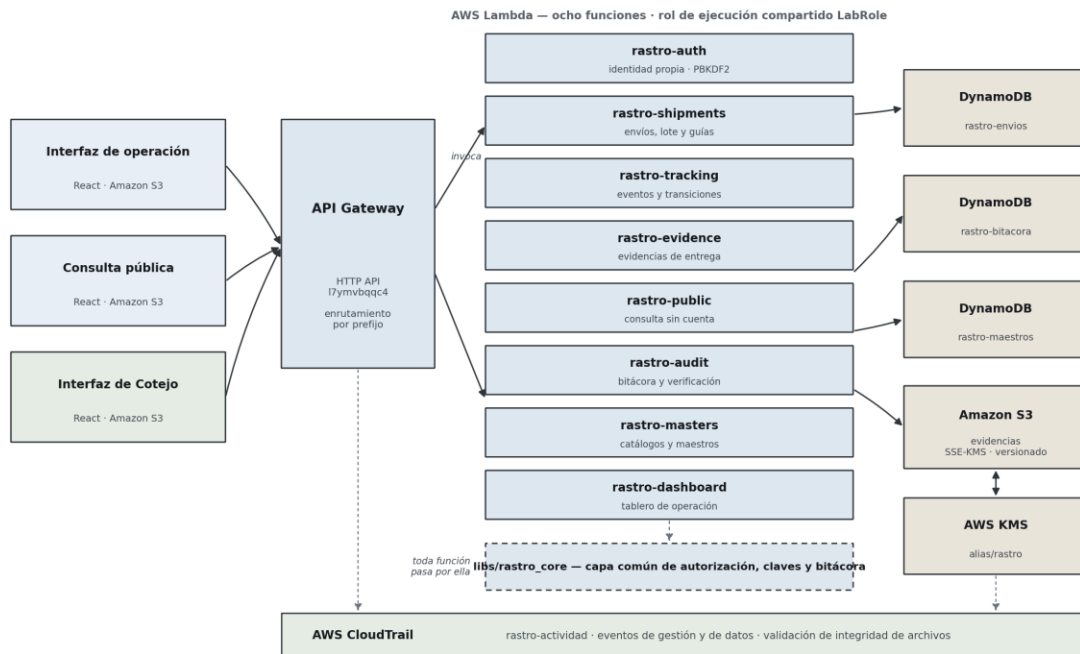
El límite de responsabilidad es explícito. Dentro de la frontera el sistema responde por la autenticación, la autorización, la integridad del registro y el cifrado en reposo. Fuera de ella quedan la seguridad física del proveedor, la disponibilidad de la región y el dispositivo del usuario final. Las dos organizaciones que comparten la infraestructura existen precisamente para poder comprobar el aislamiento: si una viera los datos de la otra, la prueba lo detectaría.

6.2 Componentes, contenedores y topología

La Figura 2 detalla los componentes efectivamente desplegados y sus relaciones.

Figura 2

Componentes desplegados en la cuenta del proveedor



Nota. El uso previsto de cada servicio se ajusta a las capacidades descritas en su documentación oficial (Amazon Web Services, s. f.-a, s. f.-b, s. f.-c, s. f.-d, s. f.-e). Todos los recursos representados existen y responden; su verificación se documenta en el apartado 8. El rótulo LabRole indica que las ocho funciones comparten un mismo rol de ejecución, condición impuesta por el entorno y analizada en el apartado 10.

La topología separa cuatro planos. El de presentación son tres sitios estáticos servidos desde almacenamiento de objetos, sin cómputo asociado. El de entrada es una única puerta de enlace HTTP que enruta por prefijo hacia la función correspondiente. El de cómputo son ocho funciones sin servidor, cada una responsable de un dominio del proceso, que comparten la capa común de autorización, claves y bitácora. El de datos son tres tablas, un almacén de objetos cifrado y la llave que lo cifra.

La capa común merece una nota, porque es donde reside la garantía de aislamiento. Ninguna función construye consultas por su cuenta: todas pasan por ella, y esa capa recibe el identificador de organización del token y lo aplica sin excepción sobre la clave de partición. El recorrido completo de una tabla queda prohibido por convención de desarrollo, y su ausencia durante la operación normal se verifica en el registro de actividad.

La Tabla 8 inventaría los recursos desplegados y verificados en la cuenta.

Tabla 8

Inventario de recursos desplegados

Recurso	Identificador	Función en el sistema
Puerta de enlace HTTP	l7ymvbqqc4	Punto único de entrada. Enruta por prefijo hacia las ocho funciones.
Funciones de cómputo	rastro-auth, rastro-shipments, rastro-tracking, rastro-evidence, rastro-public, rastro-audit, rastro-masters, rastro-dashboard	Lógica de negocio repartida por dominio. Todas con el rol de ejecución compartido del laboratorio.
Tabla de envíos	rastro-envios	Envíos y sus eventos. Clave de partición compuesta por organización e identificador de envío.
Tabla de bitácora	rastro-bitacora	Registro encadenado por funciones hash, particionado por organización.
Tabla de maestros	rastro-maestros	Clientes, tiendas, transportistas, catálogo de estados y módulos.
Llave de cifrado	alias/rastro	Cifrado en reposo de las evidencias, con rotación habilitada. Se referencia por alias y no por identificador, para que la migración no exija editar código.
Almacén de evidencias	contenedor de objetos con versionado	Fotografías y comprobantes de entrega, cifrados con la llave del proyecto y con acceso público bloqueado.
Registro de actividad	rastro-actividad	Eventos de gestión y de datos con validación de integridad de los archivos de registro.

6.3 Decisiones de arquitectura

Las decisiones relevantes se registraron a medida que se tomaron, con su contexto, las alternativas consideradas y sus consecuencias. El repositorio conserva once registros de decisión; la tabla siguiente resume los que condicionan la arquitectura.

La Tabla 9 resume las decisiones de arquitectura con sus alternativas y consecuencias.

Tabla 9

Registro de decisiones de arquitectura

ID	Decisión	Alternativas consideradas	Criterio determinante	Consecuencia asumida
ADR-001	Cómputo bajo demanda sobre servicios gestionados.	Monolito en instancia de cómputo; plataforma comercial por suscripción.	El laboratorio detiene las instancias al cerrar la sesión, de modo que el punto de consulta público dejaría de responder entre jornadas.	Dependencia de un proveedor único y mayor dificultad de depuración distribuida.
ADR-002	Capa común única de acceso a datos.	Que cada función construya sus propias consultas.	Una sola consulta sin filtrar por organización basta para exponer los datos de una empresa a otra.	Todo cambio en el acceso a datos pasa por un punto único, que se vuelve crítico.
ADR-003	Identificador de envío aleatorio y no consecutivo.	Numeración secuencial legible.	Con numeración secuencial, cualquiera recorrería los identificadores contiguos desde el punto de consulta pública.	El identificador es largo y poco memorizable; se mitiga con código de barras y guías.
ADR-004	Rol de ejecución compartido, declarado como limitación.	Un rol por función con permisos acotados.	El laboratorio no permite crear roles. No es una decisión de diseño sino una restricción aceptada.	Incumplimiento del principio de mínimo privilegio, declarado como hallazgo permanente.
ADR-006	Ampliación del alcance a sistema de gestión de transporte.	Mantener las cinco operaciones de la Entrega 1.	Sin cuentas administrables, el control de acceso por rol es una demostración y no un control.	El documento debió actualizarse para no describir un sistema distinto del construido.
ADR-007	Directorio de usuarios propio en lugar del servicio gestionado del proveedor.	Grupo de usuarios gestionado por el proveedor.	El laboratorio no concede los permisos de administración necesarios y la operación diaria no puede depender de la consola del proveedor.	El equipo asume la custodia de las contraseñas. Se derivan con PBKDF2-HMAC-SHA256 y sal por contraseña.
ADR-009	Datos de operación fuera del código.	Catálogos escritos en el programa.	Un catálogo en el código obliga a desplegar para cambiar un dato de negocio.	Aparecen dos fuentes que pueden discrepar en silencio; se añadió una prueba de coherencia entre ellas.
ADR-010	Roles configurables desde los datos.	Roles fijos en el código.	Una microempresa necesita ajustar permisos sin desarrollo.	El reparto de permisos deja de ser verificable por inspección del código y exige pruebas específicas.

Nota. Los registros ADR-005, ADR-008 y ADR-011, referidos a la configuración en ejecución de la interfaz, al sistema de diseño compartido y al doble registro en la interfaz, se conservan en el repositorio y no condicionan la arquitectura del servidor.

Una decisión merece mención aparte porque resuelve un supuesto de la Entrega 1. El supuesto SU-01 preguntaba si la puerta de enlace admitiría un validador de tokens integrado. La verificación posterior al despliegue lo reporta como indeterminado, y con razón: el sistema valida el token en cada servicio, de modo que funciona igual con validador o sin él. Un supuesto que deja de importar por una decisión de diseño es un resultado mejor que un supuesto confirmado, porque elimina una dependencia en lugar de satisfacerla.

7. Diseño detallado

7.1 Modelo de datos e información

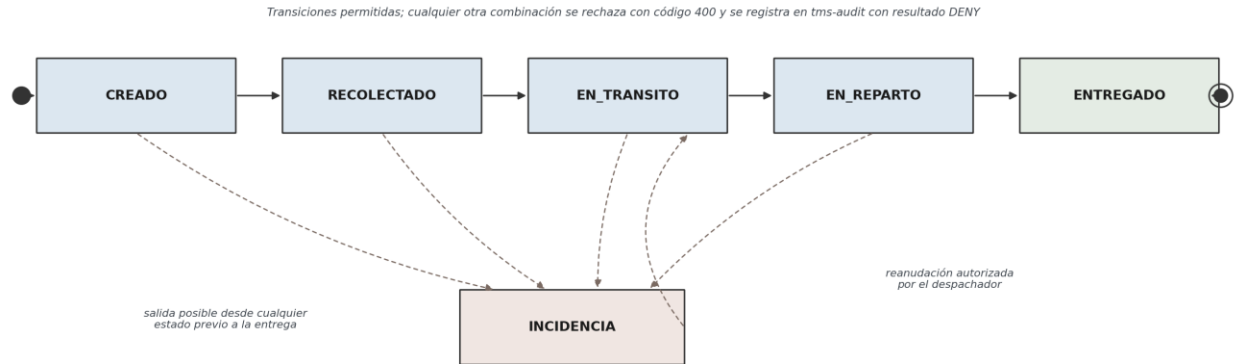
El modelo emplea una tabla principal para los envíos y sus eventos. La clave de partición combina el identificador de la organización con el del envío, y la clave de ordenamiento distingue el registro maestro de los eventos, fechados en formato ordenable. De esa forma el histórico completo se obtiene con una única consulta y en orden cronológico, y los datos de cada empresa quedan en particiones distintas. El aislamiento no depende de que el programador recuerde aplicar un filtro: sin la clave completa, que incluye la organización, la operación de lectura no puede construirse.

Una segunda tabla contiene la bitácora de auditoría, encadenada por organización. Cada registro almacena el resultado de aplicar una función hash a la concatenación del hash anterior con el contenido actual, junto con el actor, su rol, la acción, el recurso, el momento y el resultado. Toda inserción se realiza con una condición de no existencia sobre la clave, de modo que sobrescribir un registro por la vía normal resulta imposible: alterarlo exige borrarlo y recrearlo, que son dos operaciones y no una. Una tercera tabla conserva los maestros del negocio.

La Figura 3 representa la máquina de estados que gobierna el ciclo de vida de un envío.

Figura 3

Máquina de estados del ciclo de vida de un envío



Nota. El estado INCIDENCIA puede alcanzarse desde cualquier estado anterior a la entrega y su reanudación requiere autorización del despachador, lo que introduce una separación de funciones sobre la operación más sensible del proceso. El catálogo de estados incorpora además un código numérico por estado, porque el intercambio de archivos con transportistas y clientes es frágil cuando depende del nombre en texto.

El encadenamiento tiene una limitación conocida frente a escrituras concurrentes, dado que dos operaciones simultáneas pueden leer el mismo hash previo. El equipo la declara como limitación aceptada para el volumen previsto y la registra como trabajo futuro en el apartado 15.2.

7.2 Diseño de interfaces e interacción

La interfaz se construyó con criterio de móvil primero, porque la condición real del conductor es un teléfono de gama baja con conectividad intermitente. El registro de un punto de control se resolvió como una operación de un solo formulario sin campos obligatorios más allá del estado: si exigiera más pasos que enviar un mensaje, el usuario volvería a la práctica anterior y el sistema no se adoptaría.

Existen tres interfaces. La de operación reúne los recorridos de los cinco roles y presenta a cada usuario únicamente los módulos que su rol habilita, lo que evita mostrar accesos que luego el servidor rechazaría. La de consulta pública es una sola pantalla sin autenticación, en la que el

destinatario introduce el identificador y obtiene el histórico. La tercera es la interfaz del programa de auditoría, restringida al rol auditor.

Una decisión de interfaz con consecuencia de seguridad: la pantalla de acceso no muestra las cuentas de demostración. Publicar usuarios válidos en la única pantalla abierta a cualquiera es precisamente lo que un sistema real no debe hacer, aunque las credenciales sean sintéticas y el entorno sea académico.

7.3 Integraciones, API, protocolos y configuración

La comunicación entre las interfaces y el servidor es HTTP sobre TLS a través de la puerta de enlace. Salvo la consulta pública, toda operación exige un token de sesión en la cabecera de autorización. El token transporta el sujeto, sus roles y el identificador de organización; **ninguna operación acepta la organización en el cuerpo de la petición**, porque eso permitiría a un cliente declararse miembro de otra empresa.

La Tabla 10 resume el contrato de la interfaz de programación por dominio.

Tabla 10

Contrato de la interfaz de programación

Dominio	Operaciones principales	Autorización
Identidad	Obtener token, refrescar, cerrar sesión, consultar la propia cuenta, cambiar clave, administrar usuarios y roles.	La obtención de token es abierta; la administración de cuentas y roles exige rol administrador.
Envíos	Crear, consultar, listar, asignar mensajero, registro masivo, etiquetas y exportación.	Creación y asignación para administrador, despachador y coordinador. El conductor solo consulta los suyos.
Rastreo	Registrar evento y consultar transiciones permitidas.	Conductor sobre sus envíos asignados; despachador y coordinador sobre los de su organización.
Evidencias	Solicitar enlace de carga y confirmar la evidencia cargada.	Conductor sobre sus envíos asignados.

Dominio	Operaciones principales	Autorización
Consulta pública	Consultar el histórico de un envío por su identificador.	Abierta, sin token. Requiere conocer el identificador aleatorio.
Bitácora	Consultar registros y ejecutar la verificación de la cadena.	Exclusiva del rol auditor, solo lectura.
Maestros	Catálogos de estados y módulos; clientes, tiendas y transportistas.	Administrador para escritura; lectura para los roles operativos.
Tablero	Indicadores de operación.	Administrador, despachador y coordinador.

La Tabla 11 define los códigos de respuesta y su significado en el contrato.

Tabla 11

Códigos de respuesta y manejo de errores

Código	Cuándo se devuelve	Decisión de diseño asociada
200 / 201	Operación resuelta.	Devuelve el recurso afectado.
400	Transición de estado inválida o entrega sin evidencia.	El cuerpo incluye el estado de origen, el solicitado y las transiciones permitidas, para que el cliente pueda corregir.
401	Token ausente, inválido, caducado o sin organización.	Un token sin organización se rechaza aunque su firma sea válida.
403	El rol del usuario no puede ejecutar la operación.	El intento queda registrado en la bitácora con resultado DENY.
404	El recurso no existe o pertenece a otra organización.	Deliberado. Responder 403 confirmaría que el recurso existe, que es información que el solicitante no debería obtener.
409	Conflicto de escritura.	Protege el encadenamiento de la bitácora frente a escrituras simultáneas.
422	El identificador no tiene el formato esperado.	Validación previa al acceso a datos.

Nota. La distinción entre 403 y 404 es el punto más sutil del contrato y se verifica en el control C-06 de la auditoría: toda ruta de lectura debe responder 404 ante un recurso de otra organización, nunca 403.

La configuración no se escribe en el código. Los identificadores que el proveedor genera al desplegar se registran en un archivo de configuración que la interfaz lee en tiempo de ejecución, el nombre del almacén de objetos se deriva del número de cuenta, el rol se referencia por nombre y la llave de cifrado por alias. Esa regla es la que hace posible el requisito REQ-09: trasladar el sistema a otra cuenta se reduce a ejecutar la secuencia de despliegue y cargar los datos exportados.

8. Implementación, configuración y prototipo

El sistema está construido y desplegado. El repositorio público contiene alrededor de 23.500 líneas repartidas en la capa común, los ocho servicios, las dos interfaces web, el programa de auditoría, la secuencia de despliegue y las pruebas. La documentación técnica, las decisiones de arquitectura y las evidencias de despliegue viven en el mismo repositorio.

8.1 Evidencia de la implementación desplegada

La secuencia de despliegue se compone de siete etapas encadenadas más una verificación posterior, y es idempotente por necesidad y no por comodidad: las credenciales del laboratorio caducan cada cuatro horas y un despliegue interrumpido debe poder reanudarse sin dejar recursos a medias ni duplicados. Cada etapa deja su salida con marca de tiempo en la carpeta de evidencias.

La Tabla 12 recoge el resultado de la verificación posterior al despliegue.

Tabla 12

Verificación posterior al despliegue del 26 de septiembre de 2026

Grupo verificado	Componentes comprobados	Resultado
Componentes de datos	Tres tablas, llave de cifrado, contenedor de evidencias y contenedor de registro.	Los seis existen y responden.
Funciones de cómputo	Las ocho funciones del sistema.	Las ocho existen y responden.
Interfaz y registro	Puerta de enlace HTTP y registro de actividad.	Ambos existen y responden.
Prueba de extremo a extremo del punto público	Consulta de un identificador inexistente a través de la puerta de enlace.	Responde 404, que es la respuesta esperada. Confirma la ruta completa y no solo la existencia del recurso.
Prueba de extremo a extremo del catálogo	Consulta del catálogo de estados a través de la puerta de enlace.	Responde correctamente.
Supuesto SU-01	Validador de tokens integrado en la puerta de enlace.	Indeterminado y sin efecto: cada servicio valida el token por su cuenta.

Nota. Salida completa del comando de verificación con código de salida 0, conservada en el repositorio como evidencias-despliegue/20260926T232402Z-verificacion.txt. La ejecución corresponde al estado posterior a la rotación de secretos descrita en el apartado 10.

La verificación posterior al despliegue no sustituye a la auditoría, y la diferencia es deliberada: aquí se comprueba que el despliegue quedó completo, mientras que el programa de auditoría evalúa si los controles funcionan según un criterio trazado a un marco de referencia. Quien despliega no debería ser quien concluye que el control está bien.

El sistema puede además ejecutarse de forma íntegra en un entorno local con un solo comando, que levanta la pila completa con almacenamiento y base de datos simulados y siembra datos sintéticos: dos empresas, diez cuentas repartidas entre los cinco roles, catálogos y veinte envíos con recorridos variados. Esa capacidad no es un atajo sino una condición de la reproducibilidad, porque permite a un tercero ejercitar el sistema sin credenciales del laboratorio ni consumo de presupuesto.

9. Verificación, validación y pruebas

9.1 Estrategia de pruebas

La estrategia se organiza en tres niveles con propósitos distintos. Las pruebas unitarias verifican las reglas que no dependen de la infraestructura: la máquina de estados y sus códigos, el encadenamiento de la bitácora, el reparto de permisos y la derivación de claves. Las pruebas de extremo a extremo ejercitan la pila completa por sus interfaces reales y están organizadas por requisito. El tercer nivel es la auditoría independiente, ejecutada por un programa distinto del sistema y descrita en el apartado 9.3.

Dos decisiones de la estrategia merecen explicación. La primera es que ninguna prueba requiere credenciales del proveedor ni contenedores: emplean un repositorio en memoria y un almacén de evidencias simulado, de modo que se ejecutan sin consumir presupuesto y cualquiera puede

repetirlas. La segunda es que el coste de derivación de contraseñas se reduce en el entorno de pruebas, porque con el valor de producción la suite pasaba de segundos a minutos y una suite lenta es una suite que nadie ejecuta; lo que se verifica es el mecanismo y no el parámetro.

Existe además una prueba de coherencia entre fuentes que comprueba que cada módulo declarado en los datos apunta a una ruta que el enrutador define, pide un icono que el sistema de diseño sabe dibujar y un contador que la pantalla sabe resolver. Nació de un fallo real: al mover el catálogo a la base de datos aparecieron dos fuentes que podían discrepar en silencio, cuando antes una ruta mal escrita ni siquiera compilaba.

9.2 Casos, resultados y defectos

La suite completa se ejecuta con un solo comando y termina en unos catorce segundos. El resultado de la última ejecución fue de 234 pruebas superadas y 4 omitidas sobre 238 recogidas, sin fallos.

La Tabla 13 presenta el resultado de la suite por conjunto y su relación con los requisitos.

Tabla 13

Resultados de las pruebas automatizadas por conjunto

Conjunto	Pruebas	Requisitos cubiertos	Qué verifica
Unitarias de Rastro	84	REQ-03, REQ-07, REQ-08	Máquina de estados y códigos, cadena de hash, reparto de roles, derivación de claves y coherencia entre el catálogo de módulos y la interfaz.
Extremo a extremo de Rastro	120	REQ-01 a REQ-08	Los requisitos sobre la pila completa, más identidad, maestros, tablero, registro masivo, guías y módulos.
Programa de auditoría	34	Verificación indirecta de REQ-03, REQ-05 a REQ-08	Catálogo de controles, papeles de trabajo, reproducibilidad, informe y contrato con el servicio de identidad.
Total recogido	238	—	234 superadas, 4 omitidas, 0 fallos.

Nota. Las cuatro pruebas omitidas corresponden a casos que requieren condiciones no disponibles en la ejecución local y se cuentan aparte para no informar más cobertura de la que hubo. El desglose por archivo de las pruebas de extremo a extremo se conserva en el plan de pruebas del repositorio.

La Tabla 14 recoge los defectos detectados durante la construcción y su tratamiento.

Tabla 14

Defectos detectados y su resolución

ID	Defecto	Cómo se detectó	Resolución
D-01	El catálogo de módulos apuntaba a una ruta inexistente, de modo que una entrada del menú llevaba a una página vacía.	Prueba de coherencia entre la semilla de datos y el enrutador, escrita tras observar el fallo.	Corregida la ruta y añadida la prueba de coherencia, que impide la reaparición.
D-02	El secreto de firma de sesiones quedó versionado en el repositorio público.	Revisión del repositorio por el propio equipo antes de la entrega.	Rotación del secreto, redesplicue y exclusión del archivo. Detalle en el apartado 10.

Nota. Se documentan los defectos con consecuencia sobre el comportamiento o la seguridad del sistema. D-02 es el origen del hallazgo HD-01 de la matriz de retroalimentación.

9.3 Validación con usuarios o expertos

Validación con usuarios finales: no aplica en esta entrega. El proyecto no dispone de una organización de mensajería que opere el sistema en producción, de modo que no es posible medir adopción, tiempos reales de registro ni reducción de reclamaciones. El equipo se abstiene de reportar resultados de adopción que no ha medido. Lo que sí se verificó es la usabilidad de la operación crítica mediante recorridos con usuarios simulados sobre las diez cuentas sintéticas, uno por cada rol.

En sustitución de la validación con usuarios se incorporó una validación de otra naturaleza, y más exigente para los objetivos del proyecto: una **auditoría independiente de los controles**, ejecutada por un programa construido para ese fin y desarrollado como proyecto de la asignatura de Auditoría de Sistemas. El programa no lee el código ni pregunta al equipo: ejercita el sistema desplegado por sus interfaces reales, conserva la salida literal de cada prueba con su marca de tiempo y calcula una huella criptográfica de cada papel de trabajo.

La Tabla 15 resume el resultado de la auditoría independiente de controles.

Tabla 15*Resultado de la auditoría independiente sobre el sistema desplegado*

Control	Qué evalúa	Resultado	Evidencia
C-01	Registro de actividad activo y con validación de integridad de sus archivos.	Conforme	Consulta del estado del registro con el indicador de validación habilitado.
C-02	Evidencias cifradas en reposo con llave administrada y rotación habilitada.	Conforme	Cifrado por omisión con la llave del proyecto, rotación habilitada y objeto almacenado con cifrado declarado.
C-03	El almacén de evidencias no admite acceso público.	Conforme	Los cuatro indicadores de bloqueo de acceso público están activos.
C-04	El almacén conserva versiones anteriores de cada objeto.	Conforme	Versionado en estado habilitado.
C-05	Cada operación restringida a los roles autorizados, con registro del intento.	Conforme	Un conductor que intenta crear un envío recibe 403 y el intento queda registrado.
C-06	Un usuario no accede a datos de otra organización.	Conforme	Ninguna ruta de lectura cruza la frontera de organización; todas responden 404 y no 403.
C-07	El sistema rechaza transiciones de estado no contempladas.	Conforme	Las tres transiciones inválidas probadas se rechazan con 400 y quedan registradas.
C-08	La bitácora permite detectar la alteración de cualquiera de sus registros.	Conforme	La cadena verifica sobre la bitácora íntegra y las tres alteraciones deliberadas se detectan.
C-09a	Ningún secreto versionado en el árbol actual del repositorio.	Conforme	Ningún secreto en los 209 archivos del árbol actual.
C-09b	Ningún secreto en el historial de commits.	Desviado	Un secreto de firma en el historial, ya fuera del árbol actual. Origen del hallazgo HD-02.
C-09c	Ningún secreto hallado es aceptado por el sistema.	Conforme	Los dos secretos probados son rechazados por firma inválida.

Nota. Ejecución 20260926T235724886Z-4f87a8 del 26 de septiembre de 2026 contra el sistema desplegado en la cuenta 484948252891. Once controles evaluados, diez conformes y uno desviado, ninguno sin ejecutar. Cada control conserva su papel de trabajo con la salida literal y su huella.

La validación de C-08 merece destacarse porque es la única que se realiza en doble sentido. El programa comprueba que la cadena verifica sobre la bitácora íntegra y, además, altera deliberadamente una copia para confirmar que el verificador señala el punto exacto de la ruptura. Comprobar solo lo primero no demuestra que el verificador sirva: un verificador que siempre informe conformidad pasaría esa prueba.

10. Seguridad, privacidad, ética y cumplimiento

El sistema identifica cuatro amenazas y aplica un control a cada una. El acceso no autorizado a operaciones se controla con autenticación y verificación del rol en cada operación, con registro del intento. El acceso a datos de otra organización se controla con el filtro obligatorio por identificador de organización aplicado en la capa común. La enumeración de envíos desde el punto de consulta pública se controla con identificadores aleatorios no predecibles. La alteración del registro histórico se controla con el encadenamiento de la bitácora, la condición de no existencia en sus escrituras y el registro independiente de la actividad sobre la infraestructura. Los cuatro fueron verificados por la auditoría del apartado 9.3.

La Tabla 16 detalla el reparto de permisos entre los roles del sistema.

Tabla 16

Matriz de roles y permisos

Rol	Operaciones que puede ejecutar	Operaciones vedadas	Restricción estructural
Administrador	Todas las del sistema: envíos, eventos, evidencias, catálogos, tablero, cuentas y roles.	Leer y verificar la bitácora.	Opera, pero no lee el registro de sus propias operaciones. El rol no es editable: es el seguro contra quedarse sin acceso.
Coordinador	Crear y asignar envíos, registrar y reanudar eventos, descargar evidencias, editar catálogos, tablero y listado de equipo.	Administrar cuentas y roles; leer la bitácora.	Es el único rol operativo que autoriza la reanudación tras una incidencia.
Despachador	Crear y asignar envíos, registrar eventos, descargar evidencias, consultar catálogos, tablero y equipo.	Autorizar envíos detenidos, editar catálogos, administrar cuentas, leer la bitácora.	La reanudación tras incidencia queda reservada a otro rol, lo que separa quien detiene de quien reanuda.
Conductor	Ver sus envíos, registrar el avance, cargar la evidencia de entrega, consultar catálogos y tablero.	Crear o asignar envíos, descargar evidencias, leer la bitácora.	Sus operaciones alcanzan únicamente los envíos que tiene asignados.
Auditor	Consultar envíos y evidencias, leer y verificar la bitácora, listar usuarios y roles, consultar catálogos y tablero.	Cualquier operación de escritura.	Único rol que lee la bitácora. Ninguna operación de escritura lo incluye.

Nota. Ningún rol puede combinar la lectura de la bitácora con operaciones de escritura, y ninguna cuenta puede sumar dos roles que juntos lo hagan. Esa condición no es configurable, porque de ella depende la separación de funciones que el sistema promete y que el control C-05 de la auditoría comprueba. Los roles se definen en los datos y no en el código, de modo que una organización puede crear roles propios eligiendo de la lista de operaciones existentes, nunca inventando operaciones nuevas.

Incidente de seguridad gestionado durante la construcción. El archivo de configuración con el secreto de firma de sesiones quedó versionado en el repositorio público durante aproximadamente veintisiete minutos. La causa raíz no fue un descuido aislado: la exclusión del archivo existía y se retiró junto con todas las exclusiones de archivos generados, en el momento de versionar las evidencias de despliegue. La respuesta fue, en este orden, rotar el secreto y redespargar las ocho funciones, comprobar que ninguna conserva el anterior y que un token firmado con él es rechazado en las rutas protegidas, excluir de nuevo el archivo y volver a ejecutar la verificación posterior al despliegue. El análisis de la ventana de exposición no encontró indicios de explotación: las seis funciones con rutas exclusivamente protegidas no recibieron ninguna invocación en ese periodo, y las invocaciones de las dos restantes corresponden exactamente a las ejecuciones de la propia verificación.

El riesgo residual se declara: el secreto permanece en el historial de commits, y retirar un archivo no lo saca de los commits anteriores. Se acepta de forma temporal porque el secreto fue invalidado, de modo que su presencia es una limpieza pendiente y no una puerta abierta. La reescritura del historial figura como acción programada en el apartado 15.2. El propio programa de auditoría detecta esta condición en su control C-09b, lo que constituye un caso poco común y deseable: un control que encuentra un problema real de quien lo escribió.

Limitación estructural declarada. Como el entorno no permite crear roles, las ocho funciones comparten un rol único con permisos amplios en lugar de disponer cada una de uno restringido a lo que necesita. Esto incumple el principio de mínimo privilegio del pilar de seguridad del marco de buenas prácticas del proveedor (Amazon Web Services, 2024): el compromiso de cualquier

función otorgaría al atacante permisos muy superiores a los que esa función requiere. La recomendación para un despliegue productivo es un rol por función con políticas acotadas a la tabla, el prefijo del almacén y la llave que cada una utiliza. La limitación se origina en el entorno educativo y no en el diseño, y se declara en la documentación, en el código de despliegue y en todo informe de auditoría en lugar de omitirse.

De esa limitación se deriva una consecuencia que conviene enunciar con precisión, porque delimita hasta dónde llega la promesa de integridad. Frente a un usuario del sistema, el aislamiento y la autorización se sostienen. Frente a una ejecución directa con el rol compartido sobre las tablas, ningún control preventivo es posible dentro de la cuenta; lo que la arquitectura conserva es detección: la condición de no existencia obliga a que una alteración sean dos operaciones, y el registro de actividad deja constancia de ellas fuera del sistema. La inmutabilidad frente a quien administra la cuenta no se resuelve dentro de la cuenta, y requiere un ancla externa que el entorno no permite construir.

En privacidad, el sistema se pobló exclusivamente con datos sintéticos y las contraseñas de las cuentas de demostración se almacenan derivadas, no en claro. En ética, el sistema registra la ubicación de los puntos de control, que es información sobre el desplazamiento de un trabajador; la captura se limita al momento del registro del evento y no se implementa seguimiento continuo, de modo que el sistema documenta el envío y no vigila a la persona. Esa decisión se refleja en la exclusión del rastreo por posición continua declarada en el apartado 3.3.

11. Calidad, mantenibilidad y operación

Los atributos de calidad se tradujeron en mecanismos concretos y no en declaraciones. La **verificabilidad** se sostiene en la suite de 238 pruebas que se ejecuta sin credenciales ni contenedores, de modo que cualquiera puede repetirla. La **mantenibilidad** descansa en la capa

común única: el control de autorización y la escritura de la bitácora existen en un solo lugar, lo que reduce la superficie de cambio y, a cambio, concentra el riesgo en un punto que las pruebas cubren de forma específica. La **portabilidad** se resolvió prohibiendo los identificadores literales en el código, condición que hace posible reconstruir el sistema en otra cuenta ejecutando la secuencia de despliegue.

La **operabilidad** se apoya en tres elementos: la secuencia de despliegue idempotente, que puede reanudarse tras una interrupción por caducidad de credenciales; la verificación posterior, que comprueba componente por componente y devuelve un código de salida utilizable en automatización; y el procedimiento de migración a otra cuenta, previsto porque el agotamiento del presupuesto es una contingencia esperada y no un imprevisto.

Sobre la deuda técnica reconocida, el equipo señala tres elementos. El encadenamiento de la bitácora no resuelve la concurrencia de escrituras. La derivación de contraseñas emplea PBKDF2 y no un algoritmo con resistencia a hardware dedicado, porque este último exige una dependencia compilada para una plataforma distinta de la del paquete de funciones. Y el historial del repositorio conserva un secreto invalidado. Los tres figuran en el trabajo futuro con su justificación.

12. Gestión del proyecto

12.1 Metodología, fases y roles

El proyecto siguió un enfoque iterativo e incremental con una condición propia: ningún requisito se dio por cumplido antes de tener su prueba automatizada. Esa regla convirtió la verificación en parte de la construcción y no en una fase posterior, y explica que la suite creciera al mismo ritmo que el sistema. No se adoptó un marco ágil completo, porque un equipo de tres personas con

dedicación parcial no sostiene sus ceremonias; se conservaron dos prácticas: incrementos entregables al cierre de cada fase y una revisión semanal breve.

La Tabla 17 presenta las fases ejecutadas con sus responsables y su estado.

Tabla 17

Fases del proyecto, responsables y estado

Fase	Actividades	Responsable	Estado
F1. Diagnóstico y validación de supuestos	Levantamiento del proceso, verificación de las capacidades del entorno y pruebas preliminares sobre permisos y exposición.	Oscar Julián Rincón	Cerrada. Resultados en la Entrega 1 y en el apartado 3.3.
F2. Diseño	Modelo de datos, matriz de autorización, máquina de estados, encadenamiento de la bitácora y plan de pruebas.	Sergio Alejandro Montoya	Cerrada. Once decisiones registradas.
F3. Construcción y despliegue	Capa común, ocho servicios, dos interfaces, secuencia de despliegue y migración.	Nicolás Torres (desarrollo); Sergio Montoya (infraestructura)	Cerrada. Desplegado y verificado el 26 de septiembre de 2026.
F4. Verificación y cierre	Ejecución de la suite, auditoría independiente de controles, gestión del incidente de seguridad y documentación final.	Oscar Julián Rincón	En curso. Cierra con esta entrega.

12.2 Cronograma e hitos

Los cuatro hitos comprometidos se cumplieron. El primero fue la confirmación de que el entorno soportaba el diseño, obtenida mediante pruebas mínimas antes de construir sobre cada capacidad crítica. El segundo fue el documento de diseño con sus decisiones registradas. El tercero fue el despliegue operativo, alcanzado el 26 de septiembre de 2026 con verificación completa. El cuarto es el informe de verificación, que esta entrega consolida.

La desviación principal respecto del cronograma de la Entrega 1 fue la ampliación del alcance, que absorbió tiempo previsto para la fase de verificación. Se gestionó manteniendo la regla de que

ningún requisito se cierra sin prueba, de modo que el crecimiento del sistema no degradó la cobertura.

12.3 Repositorio, versiones y gestión de cambios

El repositorio público del proyecto es <https://github.com/Serann10255/Rastro>. Contiene el código de la capa común, los ocho servicios, las dos interfaces, el programa de auditoría, la secuencia de despliegue, la documentación técnica, los once registros de decisión de arquitectura, el plan de pruebas y las evidencias de despliegue con su marca de tiempo.

La gestión de cambios sigue tres reglas. Toda decisión con consecuencia sobre la arquitectura se registra antes de implementarla, con su contexto, sus alternativas y sus consecuencias. Los cambios relevantes se documentan con fecha en una carpeta específica. Y las evidencias de prueba se archivan con el comando ejecutado, su salida completa y la fecha, de modo que un tercero pueda repetir la verificación.

Los papeles de trabajo del programa de auditoría **no se versionan en el repositorio**, y la exclusión es deliberada: enumeran las debilidades del sistema y publicarlos en un repositorio público sería repetir el error que originó el incidente del apartado 10. Se entregan de forma directa al evaluador.

Declaración de uso de herramientas de inteligencia artificial. El equipo utilizó Claude, un asistente conversacional basado en modelos de lenguaje de gran escala (Anthropic, 2026), como apoyo en la redacción y la estructuración de este documento, en la elaboración de las figuras y en el diagnóstico de errores. La idea del proyecto, las decisiones de arquitectura, el desarrollo del sistema, la ejecución del despliegue y de las pruebas y la gestión del incidente de seguridad corresponden a los integrantes del equipo, que asumen la responsabilidad sobre la exactitud del contenido y sobre la verificación de las fuentes citadas.

12.4 Presupuesto y recursos

El presupuesto disponible es de 50 dólares por cuenta del laboratorio. La arquitectura opera bajo el modelo de pago por uso, de modo que el gasto depende del volumen de operaciones y no del tiempo transcurrido; el único componente con cargo fijo mensual es la llave de cifrado administrada por el proyecto. El riesgo presupuestal no proviene del volumen de uso, que en pruebas es marginal, sino de dejar activo un recurso que factura de forma continua: el proyecto excluye deliberadamente los motores de base de datos administrados, los balanceadores de carga y las pasarelas de traducción de direcciones, y esa exclusión es la principal medida de control del gasto.

El equipo no reporta cifras de consumo que no haya verificado. La cuantificación con la calculadora oficial de precios queda como actividad pendiente y se declara como tal. Los recursos humanos fueron tres integrantes con dedicación parcial durante el periodo académico.

13. Viabilidad y gestión de riesgos actualizadas

Las cuatro dimensiones de viabilidad evaluadas en la Entrega 1 se actualizan con el resultado obtenido. La **técnica** queda confirmada: el sistema está desplegado y verificado, y el único supuesto pendiente se resolvió por una decisión de diseño que lo volvió indiferente. La **operativa** se mantiene como viable con condiciones, porque el proyecto no dispone de usuarios reales y la adopción no puede medirse. La **económica** se sostiene, con la salvedad de que el consumo no se ha cuantificado con la herramienta oficial. La **legal y ética** queda cubierta por la operación exclusiva con datos sintéticos y por las decisiones declaradas en el apartado 10.

La Tabla 18 actualiza el estado de los riesgos identificados y añade los materializados.

Tabla 18

Riesgos actualizados con su estado al cierre de la entrega

ID	Riesgo	Prob.	Impacto	Estado al cierre	Respuesta aplicada
R-01	El consumo agota el presupuesto de la cuenta.	Media	Alto	No materializado	Exclusión de recursos que facturan entre sesiones y despliegue reproducible para poder migrar.
R-02	El laboratorio bloquea algún servicio previsto.	Media	Alto	Materializado y resuelto	Ocurrió con la invocación anónima de funciones. Se adoptó la puerta de enlace HTTP, verificada en el despliegue.
R-03	El alcance crece y el sistema no se termina.	Alta	Alto	Materializado y gestionado	El alcance creció por decisión registrada. Se contuvo manteniendo la regla de no cerrar requisitos sin prueba; los nueve comprometidos se cumplieron.
R-04	La expiración de credenciales interrumpe el trabajo.	Alta	Bajo	Materializado, impacto contenido	La secuencia de despliegue es idempotente y puede reanudarse sin dejar recursos duplicados.
R-05	Una consulta o un enlace se construye sin filtrar por organización.	Media	Muy alto	No materializado	Capa común única de acceso a datos y clave de partición que incluye la organización. Verificado por el control C-06.
R-06	No se consigue acceso a una organización para levantar evidencia del problema.	Alta	Alto	Materializado	La limitación se declara en el apartado 3.1 y la validación con usuarios se reporta como no aplicable en el 9.3.
R-07	Un identificador de la cuenta queda escrito en el código y la migración falla.	Media	Alto	No materializado	Prohibición de identificadores literales; nombres derivados del número de cuenta y llave referenciada por alias.
R-08	Exposición de credenciales o secretos del sistema.	Media	Muy alto	Materializado y corregido	Riesgo no previsto en la Entrega 1. Se materializó, se detectó por revisión propia y se corrigió con rotación y redespliegue. Detalle en el apartado 10.

Nota. R-08 se incorpora en esta entrega. Su omisión en la matriz inicial fue un defecto del análisis de riesgos: un proyecto que publica su código en un repositorio abierto debió contemplar la exposición de secretos desde el principio.

14. Resultados y discusión

El resultado principal es que los nueve requisitos comprometidos se cumplen y que su cumplimiento puede comprobarse por terceros. Esa segunda mitad es la que interesa: el proyecto no afirma que el registro sea verificable, sino que aporta el procedimiento con el que cualquiera puede comprobarlo. Las 234 pruebas en verde, la verificación posterior al despliegue y los once controles auditados son tres formas independientes de llegar a la misma conclusión, y ninguna depende de la palabra del equipo.

Frente a los antecedentes del apartado 4, el aporte se ubica donde la revisión identificó el vacío. La literatura sobre registros a prueba de manipulación se ha aplicado sobre todo a sistemas de gran escala y a contextos forenses; las soluciones de rastreo al alcance de una microempresa no incorporan esa propiedad. Este proyecto la incorpora y, además, la somete a una verificación en doble sentido: el control C-08 no solo comprueba que la cadena válida sobre una bitácora íntegra, sino que detecta la ruptura cuando esta se introduce deliberadamente. Comprobar únicamente lo primero no demuestra que el verificador sirva.

El resultado negativo también debe reportarse. Un control de once resultó desviado: un secreto de firma permanece en el historial del repositorio. No es un defecto menor por su origen, porque nació de un error de gestión del propio equipo, pero sí está acotado en su efecto, porque el secreto fue invalidado y se comprobó que el sistema lo rechaza. Lo que este episodio muestra, y que el equipo considera el hallazgo más instructivo del proyecto, es que un control automatizado detectó un problema real de quienes lo escribieron. Ese es exactamente el argumento a favor de automatizar la verificación en lugar de confiarla al criterio de quien construyó el sistema.

Dos limitaciones acotan el alcance de estas conclusiones. La primera es que no hubo usuarios reales, de modo que el proyecto demuestra que el sistema funciona pero no que resuelva el

problema en operación; medir reducción de reclamaciones o de tiempo de reconstrucción exigiría un despliegue con una empresa. La segunda es que el rol de ejecución compartido impone un techo a la garantía de integridad: frente a quien administra la cuenta, el esquema ofrece detección y no prevención, y esa distinción se ha mantenido explícita en todo el documento en lugar de suavizarse. Sobre la evolución del proyecto, la ampliación del alcance merece una lectura crítica. Construir un sistema de gestión de transporte completo en lugar de cinco operaciones aportó realismo y permitió que el control de acceso por rol fuera un control y no una demostración, pero consumió tiempo previsto para la verificación y elevó el riesgo de no terminar. La decisión se sostiene por el resultado, aunque el equipo reconoce que el margen fue menor del prudente.

15. Conclusiones, recomendaciones y trabajo futuro

15.1 Conclusiones

El sistema construido responde la pregunta de proyecto: es posible registrar de forma verificable el ciclo de vida de un envío, con control de acceso por rol y aislamiento entre organizaciones, dentro de las restricciones de permisos y presupuesto de un entorno educativo. La respuesta está sostenida por evidencia reproducible y no por afirmaciones.

Las restricciones del entorno resultaron ser un insumo de diseño y no un obstáculo. La imposibilidad de mantener cómputo persistente condujo a una arquitectura bajo demanda; la volatilidad del entorno obligó a un despliegue reproducible que después se convirtió en un requisito de valor propio; y la imposibilidad de crear roles produjo la limitación más importante del proyecto, que se declaró en lugar de disimularse.

La práctica que el equipo considera más transferible es haber tratado la verificación como parte de la construcción. Ningún requisito se cerró sin su prueba, y esa regla sostuvo la cobertura incluso

cuando el alcance creció. La segunda práctica es haber sometido el sistema a una auditoría automatizada e independiente, que encontró un problema real que la revisión manual no había detectado.

15.2 Recomendaciones y trabajo futuro

Cada línea indica su responsable sugerido, su prioridad, el esfuerzo estimado, aquello de lo que depende y el criterio con el que se considerará cerrada. Las que dependen de permisos o recursos que el entorno educativo no concede se señalan como tales, para que su prioridad no se confunda con una promesa de plazo.

La Tabla 19 relaciona cada acción correctiva con su responsable, su prioridad y su criterio de cierre.

Tabla 19

Plan de acciones correctivas y trabajo futuro

Acción	Responsable sugerido	Prioridad	Tiempo estimado	Dependencia	Criterio de cierre
Reescribir el historial del repositorio para retirar el secreto invalidado.	Nicolás Torres	Alta	2 horas	Acuerdo del equipo para volver a clonar tras forzar la actualización de la rama.	El control C-09b del programa de auditoría informa conforme en una ejecución posterior.
Asignar un rol de ejecución por función con políticas acotadas.	Sergio Montoya	Alta	1 semana	Permiso para crear roles de identidad y acceso, no concedido por el entorno.	Cada función opera con un rol restringido a su tabla, su prefijo y su llave, y el hallazgo permanente se cierra.
Validar el sistema con una organización de mensajería en operación.	Oscar Rincón	Alta	Un semestre	Acceso a una empresa del sector y autorización de tratamiento de datos.	Se miden tiempo de registro, reclamaciones y adopción sobre operación real.
Anclar el hash de cierre diario de la bitácora fuera de la cuenta auditada.	Sergio Montoya	Media	3 semanas	Llave con política separada del rol de ejecución o	Un tercero comprueba que la cadena actual corresponde a la sellada

Acción	Responsable sugerido	Prioridad	Tiempo estimado	Dependencia	Criterio de cierre
				segunda cuenta, no disponibles.	previamente sin acceder a la cuenta.
Resolver la concurrencia de escrituras en el encadenamiento de la bitácora.	Nicolás Torres	Media	1 semana	Ninguna.	Una prueba con escrituras simultáneas produce una cadena que verifica sin intervención.
Migrar la derivación de contraseñas a un algoritmo resistente a hardware dedicado.	Nicolás Torres	Baja	1 semana	Dependencia compilada para la plataforma del paquete de funciones.	Las contraseñas existentes migran sin recrear cuentas y la suite completa sigue en verde.

Nota. La prioridad responde al riesgo que la acción reduce y no a su facilidad. Tres de las seis dependen de permisos o recursos que el entorno educativo no concede, y su tiempo estimado corresponde al esfuerzo de ejecución una vez levantada esa dependencia.

La recomendación principal para quien retome el proyecto es conservar la regla que lo sostuvo: no cerrar un requisito sin su prueba, y no afirmar en el documento nada que no pueda comprobarse ejecutando algo.

Referencias

Amazon Web Services. (2024). AWS Well-Architected Framework: Security pillar.

<https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html>

Amazon Web Services. (s. f.-a). Amazon API Gateway developer guide.

<https://docs.aws.amazon.com/apigateway/latest/developerguide/>

Amazon Web Services. (s. f.-b). Amazon DynamoDB developer guide.

<https://docs.aws.amazon.com/amazondynamodb/latest/developerguide/>

Amazon Web Services. (s. f.-c). AWS CloudTrail user guide.

<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/>

Amazon Web Services. (s. f.-d). AWS Key Management Service developer guide.

<https://docs.aws.amazon.com/kms/latest/developerguide/>

Amazon Web Services. (s. f.-e). AWS Lambda developer guide.

<https://docs.aws.amazon.com/lambda/latest/dg/>

Anthropic. (2026). Claude (versión Opus 5) [Modelo de lenguaje de gran escala].

<https://claude.ai>

Center for Internet Security. (s. f.). CIS Amazon Web Services Foundations Benchmark.

https://www.cisecurity.org/benchmark/amazon_web_services

Congreso de la República de Colombia. (2012, 17 de octubre). Ley 1581 de 2012. Por la cual se dictan disposiciones generales para la protección de datos personales. Diario Oficial No. 48.587.

Haber, S., & Stornetta, W. S. (1991). How to time-stamp a digital document. *Journal of Cryptology*, 3(2), 99-111. <https://doi.org/10.1007/BF00196791>

- International Organization for Standardization. (2022). ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements.
- Kent, K., & Souppaya, M. (2006). Guide to computer security log management (NIST Special Publication 800-92). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-92>
- Ministerio de Comercio, Industria y Turismo de Colombia. (2013, 27 de junio). Decreto 1377 de 2013. Por el cual se reglamenta parcialmente la Ley 1581 de 2012.
- OWASP Foundation. (2021). OWASP Top 10:2021 — A01:2021 Broken access control.
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- OWASP Foundation. (s. f.). Password storage cheat sheet.
https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. ACM Transactions on Information and System Security, 2(2), 159-176.
<https://doi.org/10.1145/317087.317089>

Anexos técnicos

Todos los anexos residen en el repositorio público del proyecto, <https://github.com/Serann10255/Rastro>, con permisos de lectura abiertos.

La Tabla 20 relaciona cada anexo con su ubicación y el apartado que lo cita.

Tabla 20

Anexos técnicos y su ubicación

Anexo	Ubicación en el repositorio	Apartado que lo cita
Visión general de la arquitectura	documentacion/arquitectura/vision-general.md	6.1 y 6.2
Registros de decisión de arquitectura	documentacion/decisiones/ (once registros)	6.3
Modelo de datos	documentacion/base-de-datos/modelo-de-datos.md	7.1
Contrato de la interfaz de programación	documentacion/api/contratos.md	7.3
Secuencia de despliegue y migración	deploy/aws/	8.1 y 12.3
Evidencias de despliegue y verificación	evidencias-despliegue/	8.1
Gestión del incidente de seguridad	documentacion/cambios/2026-09-26-h01-secreto-expuesto.md	10
Plan de pruebas y trazabilidad	documentacion/pruebas/plan-y-trazabilidad.md	9.1 y 9.2
Suite de pruebas automatizadas	tests/ y cotejo/tests/	9.2
Guía de instalación y uso	documentacion/guias/instalacion-y-uso.md	8.1

Nota. Los papeles de trabajo del programa de auditoría no figuran en el repositorio por la razón expuesta en el apartado 12.3; se entregan de forma directa al evaluador.